EE6102

QUESTIONS & ANSWERS

PART 1

Q 1. What is cyber security?

- Cyber security means protection of internet connected resources such as:
  - Hardware
  - Software
  - Data
- FROM UNAUTHORIZED
  - Use
  - Modification
  - Theft
- EXAMPLES: John uses Internet to copy Mary's data and then crashed her system.
- Henry spoofs Julie's IP address to gain access to her computer.
- John steals ABC bank data and sales to A-government for $2 millions.
- Thus, cyber-security refers to the policies, procedures, and technical measures that can be applied to prevent unauthorized access, alteration, theft, or physical damage to smart devices and information systems.

Q2. Suppose that a network computer virus is designed such a way that as soon as it is copied onto a computer, X, it simply copies itself to six of computer X's neighboring computers and each time it uses a random file name, in order to evade detection. The virus itself does not cause any other damage (it doesn't read, delete or modify any other files). What harm would be done by such a virus and how would it be detected?

- This problem is based on the true story of the Cornell graduate student, Robert Morris.
- His virus (which is more properly called a “worm") brought the entire Internet to its knees. 原因是当病毒将自己复制到X的邻居时，这些邻居会将病毒再复制回X六次，而X又会将病毒的36个副本复制到它的邻居，如此反复。
- The reason is that when the virus copies itself to X's neighbors, they will copy it back six times to X, which then copies 36 copies to its neighbors, and so on.
- Soon all of X's disk memory will be full of copies of the virus. It will also use all the available bandwidth, and CPU, which will eventually crash X. Therefore, this is a type of denial-of-service (DoS) attack.
- This sort of attack is very easy to launch, and this method has been successfully employed, particularly via Gmail and other similar services.
- The detection is basically done by looking for unusual activities regarding mail, speed or when suddenly there is huge surge in internet traffic, which will require proper investigation.

Q3. Describe various types of cyber security threats and explain why despite huge advances in technology and encryption techniques it is not possible to provide 100% security for a smart device connected to an internet.

- Various Types of attacks and Various Types of attackers
- Criminal Attacks: Basis is in financial gain. Includes fraud, destruction and theft (personal, brand, identity)
- Privacy Violations: Private/personal information acquired by organizations not authorized. Includes surveillance, databases, traffic analysis.
- Publicity Attacks: Attacker wants to get their name(s) in the papers. Can affect ANY system, not just related to profit centers 公关攻击、希望得到媒体曝光
- Automation: Speed of computers and networks makes minimal rate of return attacks possible. Data mining is easy and getting easier, affecting privacy 最小回报率
- Action at a Distance: Attackers can be far away from their prey and still do damage. Interstate/International differences in laws can affect prosecution 起诉
- Electronic techniques easily transferable/duplicated: Counterfeiting e-money. Attack tools can be created by single person. Easily modified per situation
  伪造电子货币
  且容易基于情况修改
- Therefore, Impossible to obtain perfect security
  易用性、可用性
- Security is a balance between protection, ease of use and availability.
- It is not possible to make any system 100% secure against cyber attacks.

Q4. The “Ransomware” attacks of May 2017, affected over 300,000 devices in 150 countries resulting in estimated cost of over $5+ billion. Discuss the working of Ransomware virus and how it is spread?

- Ransomware is a kind of cyber attack that involves hackers taking control of a computer system and blocking access to it until a ransom is paid. 赎金
- For cyber criminals to gain access to the system they need to download a type of malicious software onto a device within the network. This is often done by getting a victim to click on a link or download it by mistake.
- Once the software is on a victim's computer the hackers can launch an attack that locks all files it can find within a network. gradual：逐步的
- This tends to be a gradual process with files being encrypted one after another.
- The victims are contacted and asked to pay ransom money via cryptocurrencies as the attackers don’t want to be tracked and eventually captured. 加密货币
- In some cases, even when victims pay the ransom amount, they don’t get their data. For this purpose, there are many companies who offer to be mediators. Once the negotiated amount is paid to the attackers, the mediator company will make sure that the victims gets their data. Even though this is not a good trend, in some cases companies have no other choice. mediators：中介服务
- Even famous organizations like Acer, have paid huge ransom amount to get their data.

Q5. What is ransomware?

- Malicious software that locks a device, such as a computer, tablet or smartphone and then demands a ransom to unlock it

Q6. Where did ransomware originate?

- The first documented case appeared in 2005 in the United States, but quickly spread around the world.

伪装成电子邮件的附件

Q7. How does it affect a computer?

- The software is normally contained within an attachment to an email that masquerades as something innocent. Once opened it encrypts the hard drive, making it impossible to access or retrieve anything stored on there – such as photographs, documents or music.

Q8. How can you protect yourself?

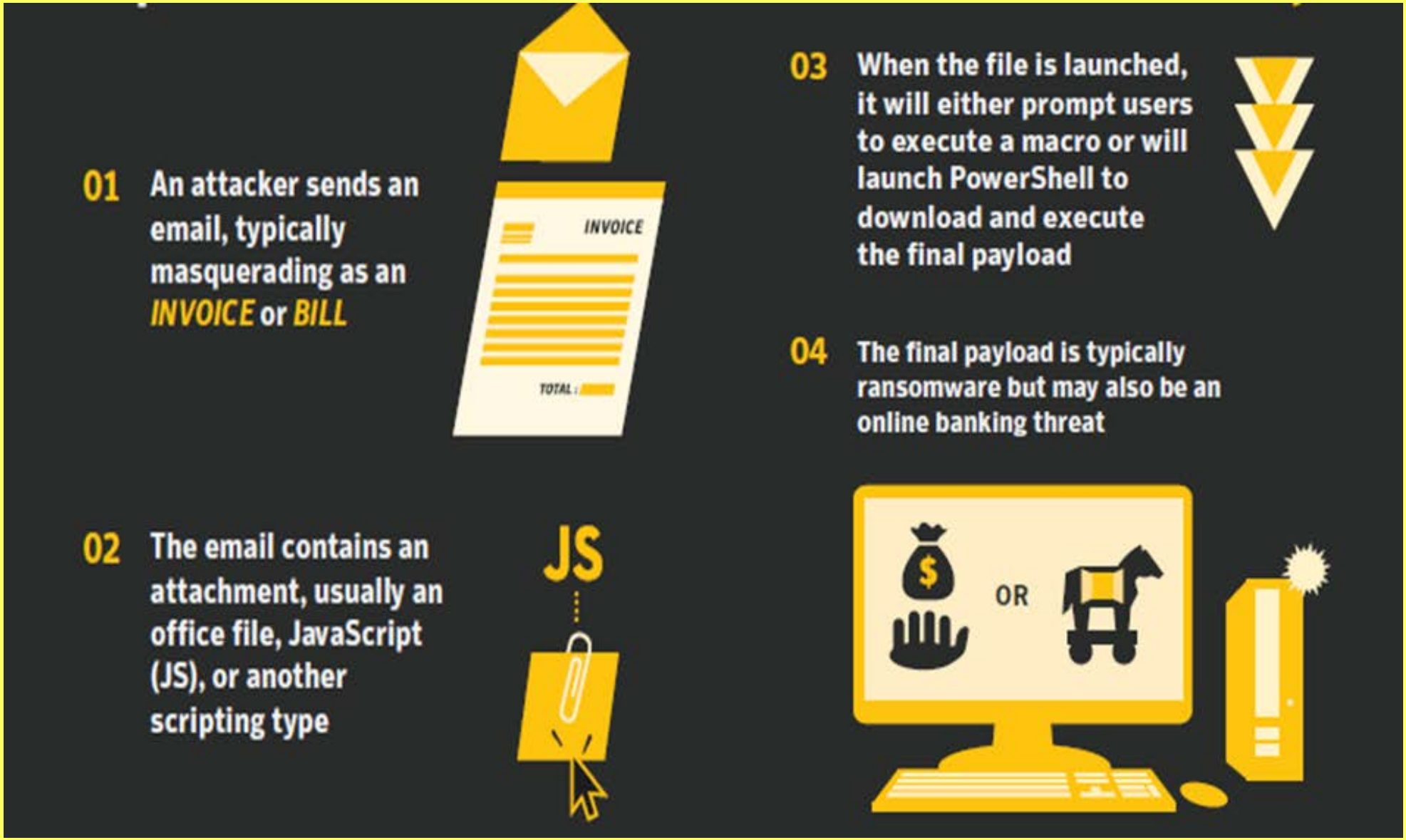
- Anti-virus software can protect your machine, although cybercriminals are constantly working on new ways to override such protection.

Q9. How much are victims expected to pay?

- The ransom demanded varies. On average victims were asked to pay $300 in bitcoins. However, there's no guarantee that paying will get your data back.
- Large organizations are asked to pay higher amount. Acer paid $50M and some other large organizations and USA government paid several millions.

MALWARE INFECTION PROCESS

当文件被打开时，它会提示用户执行宏，或者会启动PowerShell来下载并执行最终的恶意负载。



Q10. How one can protect itself from Ransomware attack? back up：备份

- The best protection against ransomware attacks is to have all files backed up in a completely separate system. This means that if you suffer an attack, you will not loose any information to the hackers.
- It is difficult to prevent determined hackers from launching a ransomware attack, but exercising caution can help. Cyber attackers need to download the malicious software onto a computer, phone or other connected device.
- The most common ways of installing the virus are through compromised emails and websites.
- Educate yourself and use technology to protect your devices.

Q11. On Tuesday, 27June 2017, second wave of "Ransomware" attacks was successfully launched. Explain why the lessons were not learnt from the first wave of attacks and why the second wave was also successful? lessons were not learnt：未能汲取教训

- Most organizations didn't have security policies in place to handle this sort of situation and when the second wave of attack was launched, they just didn't know what to do and thus the second wave was also successful. 未能建立处理此类情况的安全政策；

Q12. Was the reasons for "Ransomware's" success due to lack of technical expertise or due to lack of policies and its enforcements?

- It was due to both technical and nontechnical aspects of information security. What needed is: 补丁
- Patching: Microsoft had issued patches two months ago; however, infected computers were not updated. 培训
- Training: 83% ransomware attacks originate when an employee clicks on a malicious link. so, investing in training about protecting against phishing and malware should be a priority.

Q13. Eve installed some spyware software on 1000 USB flash drives and has designed this software to auto load from these drives along with some photos of a famous star. She then painted the logo of a well-known magazine on each one and randomly scattered these flash drives in the parking lots of several large companies in her town. What type of malware attack is this and what vulnerability is she trying to exploit in order to get her malware code past the network firewalls of these companies?

- This is a Trojan horse attack, since the users are probably expecting the photos of famous star, given the logo, but are not expecting the spyware. vulnerability：漏洞
- Eve is trying to get employees of these companies to insert these USB flash drives in their company computers (inside the firewall) and exploit a vulnerability of having auto-execution enabled, so that the spyware auto loads along with the expected photos. She is exploiting social engineering.

Q14. Suppose you want to use an Internet cafe to login to your personal account on a bank web site, but you suspect that the computers in this cafe are infected with software keyloggers. Assuming that you can have both a web browser window and a text editing window open at the same time, describe a scheme that allows you to type in your userID and password so that a keylogger, used in isolation of any screen captures or mouse event captures, would not be able to discover your userID and password.

- Open both the web browser, pointing to your bank's login page, and a text editing window to open a new un-named file.
- To enter your userID and password, use your mouse to toggle input between the text editor and the web browser. 单个字符
- When you are in the browser window type a single character of your userID or password and then click back to the text editor window. reasonably long”：较长的
- When you are in the text editor window, type a reasonably long sequence of random characters.
- By toggling back and forth between these two windows you will end up typing in your userID and password, but a keylogger will only see a sequence of random characters with the characters of your userID and password intermixed in such a way as to be hard to detect. toggling back and forth：来回切换；

Q15. What is the difference between a skilled hacker and an unskilled hacker (other then the lack of skill)? How does protection against each differ?

- An expert hacker is one who develops software scripts and codes to exploit relatively unknown vulnerabilities. 相对未知的漏洞
- The expert hacker is usually a master of several programming languages, networking protocols, and operating systems.
- An unskilled hacker (script kiddies or hackers in training) is one who uses scripts and code developed by skilled hackers.
- They rarely create or write their own hacks, and are often relatively unskilled in programming languages, networking protocols, and operating systems.
- Protecting against an expert hacker is much more difficult, due to the fact that most of the time the expert hacker is using new attack code. This makes it almost impossible to guard against these attacks at first (Zero day attack).
- On the other hand, an unskilled hacker generally uses hacking tools that have been made publicly available. Therefore, protection against these hacks can be maintained by staying up-to-date on the latest patches and being aware of hacking tools that have been published by expert hackers.

Q16. Why it is easy to find secrete information (like password, credit card, social security etc.) via social engineering and social networks?

- Social networking websites allow you to share messages, pictures, files and even up-to-the-minute information about what you are doing and where you are.
- Social networking sites are owned by private businesses, and that they make their money by collecting data about individuals and selling that data, particularly to third party advertisers. 社交网络网站由私人企业拥有，通过收集个人数据并将这些数据卖给第三方广告商来获利。

- When you enter a social networking site, you are leaving the freedoms of the internet behind and are entering a network that is governed and ruled by the owners of the site.
- Most social networking risks are old scams with new twists. During a lunch break at work, you receive a Facebook post that seems like it's from a friend. It's impossible not to click. 大多数社交网络的风险都是旧骗局的新变种
- Social engineers mine social networks to build trust and exert influence. A social engineer's greatest tool of deception is to gain your trust, which is easy once they know your likes, friends and updates that you publish daily.

Q17. I am using an unsecured Wi-Fi from a neighbour. Am I compromising my cyber security?

- Login Information Interception: Data transmitted over unsecured Wi-Fi can be intercepted by third parties. These third parties can extract your login information and passwords from this intercepted data and use it to fraudulently access your services. This can include online banking, email and other services that can be used to facilitate identity theft. interception：拦截 illicit：非法
- Sensitive Information Interception: Information sent in instant messages, emails and other data-transmission tools can also be intercepted and put to illicit use. When transmitting sensitive corporate information, this can be an especially dangerous security risk. corporate：公司 compromised：受损的
- Compromised Devices: Compromised devices may also be connected to Wi-Fi.
- Malicious Hotspots: Most dangerously, the hotspot you connect to itself may be malicious. hotspots：热点；
- Using unsecured Wi-Fi networks is risky business that can lead to identity theft and credit fraud.

Q18. What are the two aspects of computer security and explain why computer security strategies that are technology-centric or policy-centric always fail. Also suggest ways to overcome this major problem?

- Technological (Hardware, Software, Network)
- Managerial (policies, procedures)

- TECHNICAL
  - Main focus is on developing technical expertise and technologies for computer security.
- MANAGERIAL
  - The focus is on developing security policies and procedures.
- Basically, these two groups of people in any organization have different roles and functions.
- The problem arises because both groups don't understand and appreciate each other's work.
- Without each other's cooperation, they will not succeed.

Tier 1	Senior management commitment and support
Tier 2	Acceptable-use policies and other statements of practice
Tier 3	Secure-use procedures
Tier 4	Hardware, software, and network security tools

- Technology-centric strategies are weak without strong policies and practices.
- Policy-centric strategies are ineffective without technology to monitor and enforce them.
- What is needed is a comprehensive multi faceted approach based on:
  - Senior management support
  - Strong and sensible policies
  - Practical procedures.
  - Modern Security Technologies

comprehensive：全面的
senior management：高层
vital：至关重要的
proper execution：正确执行；

- Because all four play a vital role in the proper execution of a computer security program.
- Management is responsible
- Information security is 信息安全是一个管理问题，同时也是一个人员问题
  - A management issue. A people issue

Q19. Assume that you have been appointed a security consultant in a start-up company which is starting branches in several countries. The higher management is not very technical; however, they do know the importance of cyber security and are all geared up to support whatever measure you are willing to take. Thus, describe the two most important steps you will take?

gear up to：全力……

- First step in cyber security planning: Identification
- Identify what the organization needs to protect and to protect against what attacks.
  - Identify the types of threat facing an organization's information systems.
- Next step in cyber security planning is to Understand vulnerabilities, which can be due to human errors or complexity of software. 识别问题、理解漏洞

Q20. In Q19, if the top management was not keen on cyber security, would you still be able to design, implement and manage the security system? If not then what would you need to do to convince the higher management that the security should be taken seriously.

- Well one can design and implement the security system, but without proper policies and enforcement, it will not be effective.
- To convince the top management, one needs to make them realize the extent of the problem and what is at risk in their own organization.
- ASSETS AT RISK
  - Data assets, Knowledge assets, Software assets, Physical assets
  - Monetary or financial assets
  - Employee assets
  - Customer and partner assets
  - Goodwill
- Employees and staff cannot be expected to change their behavior if they do not observe respect for security by their superiors.
- Management must be informed of the various kinds of threats facing the organization
- How to get management's attention?
  - News that gets attention:
    - 100,000 ecommerce Websites attacked each week!
    - Yahoo! suffered a $1 billion loss in share price directly following a DOS attack.
    - 39% of companies had downtime lasting over 8 hours from DOS attacks.
    - Theft of intellectual property is costing U.S. businesses more than $250 billion annually, according to the American Society of Industrial Security (ASIS). Much of this property drain is conducted electronically.

not keen on：对……不感兴趣

Monetary：货币
Goodwill：商誉

superiors：上级

Q21. What is cryptography and what were some of the first uses of cryptography? Most cryptography systems use a key for both encrypting and decrypting messages, thus explain what is a key, and what is it used for?

- Cryptography is the use of mathematical operations to protect messages traveling between parties or stored on a computer. sorted on：存储在；
- This first recorded use of cryptography is concealing military and political secrets while they were transported from place to place. conceal：掩盖
- The key can be a series of bits used by a computer program, or it can be a passphrase used by humans that is then converted into a series of bits for use in the computer program. passphrase：密码短语
- Key is used in conjunction with an algorithm to create the ciphertext from the plaintext or derive the plaintext from the ciphertext. conjunction：结合

Q22. What is general idea behind symmetric key and asymmetric cryptography and what are the fundamental differences between these two systems?

- The original message from Alice to Bob is called plaintext; the message that is sent through the channel is called the ciphertext.
- To create the ciphertext from the plaintext, Alice uses an encryption algorithm and a shared secret key.
- To create the plaintext from ciphertext, Bob uses a decryption algorithm and the same secret key.
- Symmetric encryption, also called private or secrete key encryption, is where the same key is used to conduct both the encryption and decryption of the message.
- Both the sender and receiver must own the same key.
- The problem with symmetric encryption is getting a copy of the key to the sender.

- Asymmetric key cryptography uses two separate keys: ONE PRIVATE AND ONE PUBLIC
- **FUNDAMENTAL DIFFERENCES**
- Asymmetric encryption also known as public key encryption uses two different keys the public key and the private key while symmetric encryption system uses only one key to encrypt and decrypt messages.
- Symmetric encryption is much faster for the computer to process; however, it raises the costs of key management as the key has to be sent to the receiver in a secure way.
- The problem with asymmetric encryption is that it requires four keys to hold a single conversation between two parties.
- Due to the number of keys involved in asymmetric encryption, it is not as efficient to use as symmetric encryptions in terms of CPU computations and key management.
- **Q23: In PKI, is it possible to drive private key from the public key?** Public Key Infrastructure
- Asymmetric algorithms are designed such a way that it is impossible to drive private key from a related public key. If it was possible to drive the private key from a matching public key, then that algorithm cannot be used. For that reason, the algorithms are tested for many years under various real-world conditions to make sure that these algorithms are not only safe theoretically, but they are also very safe in real situations as well.
- The testing is also carried out by different group of people from industry, academia, mathematic, cryptography experts and industrial users.
- Whenever any cryptographic algorithm is compromised, it is not used any more as it is not considered safe for normal applications. 非对称算法设计的方式使得从相关公钥推导出私钥变得不可能。

Q24. Describe RSA cryptosystem.

a. What is the one-way function in the system?

b. What is the trapdoor in the system

c. Define the public key and private key in the system

d. Describe the security of the system.

单向函数是 $C = P^e \mod n$。

trapdoor：后门（系统中的后门是值 d（接收者的私钥））

- The most widely used public-key algorithm is the RSA cryptosystem, named for its inventors (Rivest, Shamir, and Adleman).
- Uses exponentiation of integers, modulo, and a prime
- Encrypt: $C = M^e \bmod n$
- *Decrypt:* $M = C^d \bmod n = (M^e)^d \bmod n = M$
- Both sender and receiver know values of *n* and *e*
- Only receiver knows value of *d* 发送者和接收者都知道 n 和 e 的值，只有接收者知道 d 的值。
- Public-key encryption algorithm with
  - Public key = *e* and Private key = *d*

a. The one-way function is the **$C = P^e \bmod n$**. Given P and *e*, it is easy to calculate C; given C and *e*, it difficult to calculate P if *n* is very large.

b. The trapdoor in this system is the value of d (Bob's Private Key), which enables Bob to use $P = C^d \bmod n$ to decrypt the message.

c. The public key is e. The private key is d. 公钥是 e，私钥是 d。

d. The security of RSA mainly depend on the factorization of n.

RSA的安全性主要取决于 n 的因式分解。如果 n 足够大且选择合适的 e 值，系统就是安全的。

- If n is very large, and the value of e is chosen properly, the system is secure.

Q25. In RSA cryptosystem the message "STOP" is to be encrypted using a block of 4. Let us assume that the user has chosen two prime numbers p = 43 and q = 59 and e = 13. Show step by step, the resultant encrypted message.

- Given: p = 43, q = 59 and e = 13
- n = p*q = 43*59 = 2537
- The message STOP, need to be converted into their numerical equivalents (position in the alphabet-1) and then group those numbers into blocks of 4.
- 1819 1415 = ST OP
- We encrypt each block using $C = M^e$ MOD n
  - $C = M^{13}$ MOD 2537
  - $C = 1819^{13}$ MOD 2537 = 2081 (For ST)
  - $C = 1415^{13}$ MOD 2537 = 2182 (For OP)
- The encrypted message is thus 2081 2182.

Q26. In RSA cryptosystem an encrypted message "0981 0461" is to be decrypted using a block of 4. Let us assume that the user has chosen two prime numbers p = 43 and q = 59 and e = 13. Show step by step, the resultant decrypted the message.

- The plaintext message can be recovered as:
- $M = C^d$ mod n, where C is the encrypted message
- To calculate d, we have
- $d = e^{-1}$ mod (p-1)(q-1)
- $d = 13^{-1}$ mod (42) (58) = 13^{-1} mod 2436 = <u>937</u>
- n = p*q = 43*59 = 2537
- $M = C^d$ mod n, putting the values we have
- $M = 0981^{937}$ mod 2537 = 0704 = he (for M=0981)
- $M = 0461^{937}$ mod 2537 = 1115 = lp (for M=0461)
- Thus the decrypted message is "help"

Q25. 在RSA密码系统中，信息“STOP”将使用4个字符的分组进行加密。假设用户选择了两个素数 $p = 43$ 和 $q = 59$，以及 $e = 13$。逐步显示加密过程，结果的加密信息如下。

- 已知：$p = 43, q = 59$ 且 $e = 13$
- $n = p \times q = 43 \times 59 = 2537$
- 信息“STOP”需要转换为它们的数字等价（字母在字母表中的位置减1），并将这些数字分成4位的分组。
- $1819\ 1415 = ST\ OP$
- 我们使用公式 $C = M^e \mod n$ 对每个分组进行加密。
  - $C = 1819^{13} \mod 2537 = 2081$（对于ST）
  - $C = 1415^{13} \mod 2537 = 2182$（对于OP）
- 因此，加密的信息为 $2081\ 2182$。

Q26. 在RSA密码系统中，要解密加密信息“0981 0461”，使用4个字符的分组。假设用户选择了两个素数 $p = 43$ 和 $q = 59$，以及 $e = 13$。逐步显示解密过程，结果的解密信息如下。

- 明文信息可以通过以下公式恢复：$M = C^d \mod n$，其中 C 是加密信息。
- 计算 d 的步骤：
  - $d = e^{-1} \mod (p-1)(q-1)$
  - $d = 13^{-1} \mod (42)(58) = 13^{-1} \mod 2436 = 937$
- $n = p \times q = 43 \times 59 = 2537$
- 代入公式 $M = C^d \mod n$，我们有：
  - $M = 0981^{937} \mod 2537 = 0704$（对于 $M = 0981$ 得到 he）
  - $M = 0461^{937} \mod 2537 = 1115$（对于 $M = 0461$ 得到 lp）
- 因此，解密信息为“help”。

Q27. In RSA:

a. Given q =13, p =17, e=5 Find, φ(n) and d

b. Given q =31, and p = 127 and e = 17, find d

c. Given p =19, q=23 and e =3 Find n, φ(n)

a. $\varphi(n) = (q-1)(p-1) = (12 \times 16) = 192$

- $d = e^{-1} \bmod \varphi(n) = 5^{-1} \bmod 192 = 77$

b. $\varphi(n) = (30 \times 126) = 3780$

- $d = e^{-1} \bmod \varphi(n) = 17^{-1} \bmod 3780 = 3113$

c. $n = p \times q = 437$

- $\varphi(n) = (18)(22) = 396.$

Q28. In Public key, different keys are used for encryption and decryption. The user gives/publishes his/her public key which can be used to send him/her encrypted messages. Thus, how does a receiver know that the public key he/she is using is authentic? Is it possible to spoof a public key?

- Generally, this type of cryptosystem involves trusted third party which certifies that a particular public key belongs to a specific person or entity only.
- The digital certificate contains the user's public key and is signed by the certification authority (CA), which can be verified by using their public key.
- However, since CA are not regulated, it is possible to fraudulently obtain a public key.
- User can also self generate digital certificates.

Q. In Asymmetric cryptographic system, the public and private keys are mathematically related, thus is it possible to calculate private key from the public key, which is known?

- Though private and public keys are related mathematically, it is not be feasible to calculate the private key from the public key.

Q27. 在RSA中：

a. 已知 $q = 13$，$p = 17$，$e = 5$，求 $\varphi(n)$ 和 d

- $\varphi(n) = (q-1)(p-1) = (12 \times 16) = 192$
- $d = e^{-1} \mod \varphi(n) = 5^{-1} \mod 192 = 77$

b. 已知 $q = 31$，$p = 127$，$e = 17$，求 d

- $\varphi(n) = (30 \times 126) = 3780$
- $d = e^{-1} \mod \varphi(n) = 17^{-1} \mod 3780 = 3113$

c. 已知 $p = 19$，$q = 23$，$e = 3$，求 n 和 $\varphi(n)$

- $n = p \times q = 437$
- $\varphi(n) = (18)(22) = 396$

Q28. 在公钥加密中，使用不同的密钥进行加密和解密。用户提供/发布他的公钥，可以用来发送加密消息给他。因此，接收方如何知道他使用的公钥是可信的？是否有可能伪造公钥？

- 通常，这种加密系统涉及可信的第三方，证明特定公钥仅属于某个特定人或实体。
- 数字证书包含用户的公钥，并由认证机构（CA）签署，可通过其公钥验证。
- 但是，由于CA不受监管，可能会欺诈性地获得公钥。
- 用户也可以自我生成数字证书。

Q. 在非对称加密系统中，公钥和私钥在数学上是相关的，因此是否可以从已知的公钥计算出私钥？

- 虽然公钥和私钥在数学上相关，但计算私钥从公钥是不可行的。

- In fact, intelligent part of any public-key cryptosystem is in designing a relationship between two keys.
- It is almost impossible to obtain the private key from the public key.
- Let us assume A and B, to be very large prime numbers.
- Their product, C, is then much larger and has A and B as its only factors.
- If you give C to someone, you wouldn't be able to factor it and find A and B.

Q29. In RSA algorithm, values of two prime numbers can be made pubic or not ?

- The main source of security in RSA is keeping the two prime numbers, let us say p and q, secret and therefore also keeping φ(n) secret. 在RSA算法中，两个质数的值是否可以公开？
- It is important to realize that knowing either will reveal the other.
- That is, if you know the factors p and q, you can calculate φ(n) by multiplying p − 1 with q − 1. RSA的安全性主要来源于将两个质数（例如p和q）保密，因此也保密$\varphi(n)$。
- And if you know φ(n) and n, you can calculate the factors p and q readily.

Q30. Alice and Bob want to share a secret key for use in a symmetric cipher, but their only means of communication is insecure. Every piece of information that they exchange is observed by their adversary Eve. With the help of an example explain how Diffie-Hellman key exchange method makes it possible for Alice and Bob to share a key without making it available to Eve?

- Diffie-Hellman key exchange was first published by Diffie and Hellman in 1976 along with the exposition of public key concepts.
- It is used in a number of commercial products.
- Practical method to exchange a secret key securely that can then be used for subsequent encryption of messages. 安全性依赖于离散对数计算的困难性。
- Security relies on difficulty of computing discrete logarithms.

- The first step is for Alice and Bob to agree on a large prime p and a nonzero integer g called primitive root.
  - Alice and Bob make the values of p and g public knowledge.

g：别人是不知道的

- The next step is for Alice to pick a secret integer *a* that she does not reveal to anyone, while at the same time Bob picks an integer *b* that he keeps secret.
- Bob and Alice use their secret integers to compute.

$$\underbrace{A \equiv g^a \pmod{p}}_{\text{Alice computes this}} \quad \text{and} \quad \underbrace{B \equiv g^b \pmod{p}}_{\text{Bob computes this}}.$$

- They next exchange these computed values, Alice sends *A* to Bob and Bob sends *B* to Alice.
  - Note that Eve gets to see the values of *A* and *B*, since they are sent over the insecure communication channel.
- Finally, Bob and Alice again use their secret integers to compute.

$$\underbrace{A' \equiv B^a \pmod{p}}_{\text{Alice computes this}} \quad \text{and} \quad \underbrace{B' \equiv A^b \pmod{p}}_{\text{Bob computes this}}.$$

- The values that they compute are actually the same.

LET US HAVE

Prime number q = 353 , Primitive root g = 3

Alice chooses a = 97 and Bob Chooses b=233

Alice and Bob each compute their public keys

Alice computes $\mathbf{Y_A} = g^{a} \bmod q = 3^{97} \bmod 353 = \mathbf{40}$

Bob computes $\boldsymbol{Y_B} = g^{b} \bmod q = 3^{233} \bmod 353 = \mathbf{248}$

They exchange and compute secret key:

Alice: $\boldsymbol{K} = (Y_B)^{a} \bmod q = 248^{97} \bmod 353 = \mathbf{160}$

Bob: $\boldsymbol{K} = (Y_A)^{b} \bmod q = 40^{233} \bmod 353 = \mathbf{160}$

Q31. What is hashing and its role in cryptography? Is hashing the same thing as encrypting? Can you de-hash?

- A "hash" (also called a "digest", and informally a "checksum") is a kind of "signature" for a stream of data that represents the contents. 哈希（也称为“摘要”，非正式地称为“校验和”）是一种为一串数据生成的“签名”，代表该内容。
- The closest real-life analogy we can think is "a tamper-evident seal on a software package": if you open the box (change the file), it's detected.
- This has many uses, including verifying files, ensuring the integrity of an encrypted message. Because there isn't a key, there is no way to get the original. 确保文件完整性
- Hashing is not the same as encryption.
  - Hashing returns a value of a set size (typically much smaller than the file) based on the whole file. This is a unique value that will change if the file changes but will not increase in size. 哈希返回一个固定大小的值（通常比文件小得多），基于整个文件生成
  - Encrypting returns a file of the same size (or larger). If more data is added to the encrypted file then the overall file size will increase.
- No, you can't de-hash and get the original file as an output. It would be like determining the whole number based on part of a remainder from a long division problem. It won't work. 你不能解哈希得到原始文件作为输出
- You can decrypt but you can't de-hash.

Q32. What is Digital Signatures and how does the verifier check the digital signature?

- A digital signature (not to be confused with a digital certificate) is an electronic signature that can be used to authenticate the identity of the sender of a message or the signer of a document. 数字签名不是用来确保消息的保密性，而是用于保证发送消息的人确实是消息的发送者。这被称为不可否认性。
- A digital signature is not used to ensure the confidentiality of a message, but rather to guarantee who sent the message. This is referred to as nonrepudiation.

- Essentially, it proves who the sender is.
- Digital signatures are actually rather simple, but clever.
  - They simply reverse the asymmetric encryption process.
- Recall that in asymmetric encryption, the public key (which anyone can have access to) is used to encrypt a message to the recipient, and the private key (which is kept secure, and private) can decrypt it.
- With a digital signature, the sender encrypts something with his or her private key. If the recipient is able to decrypt that with the sender's public key, then it must have been sent by the person purported to have sent the message.
- The verifier checks the digital signature by hashing the plaintext message with the same algorithm used by the sender.
- The verifier then decrypts the digital signature it received with the true party's public key, resulting in a message digest.
- The verifier compares the two message digests – if they are the same, good to go.

Q33. What three things must the receiver of a digital certificate check to ensure that a digital certificate is valid?

- First, the verifier must check that the digital certificate is authentic and has not been modified.
  - CAs in many countries are not regulated, thus the verifier must only accept digital certs from CAs it trusts by reputation.
  - The verifier can use the CA's well-known public key to test the digital certificates digital signature; if the test works, the digital certificate is authentic and unmodified.
- Second, each digital certificate has dates before which and after which it is not valid.
  - The receiver must check whether the digital certificate is in its valid period.

- Third, even during a digital certificate's valid period, a certificate authority may revoke a digital certificate.
  - There is a Online Certificate Status Protocol (OCSP). Using OCSP, a program can simply send in the serial number of a digital certificate to the CA. The CA will send back a response saying whether the serial number is good, revoked, or unknown.

- 数字签名的原理其实很简单，但却很巧妙。
  - 它仅仅是将非对称加密过程反向使用。
  - 回忆一下，在非对称加密中，公钥（任何人都可以访问）用于加密发送给接收方的信息，而私钥（安全保管，不公开）用于解密。
  - 使用数字签名时，发送者使用其私钥加密信息的一部分。如果接收方能够使用发送者的公钥解密该部分信息，那么该信息一定是发送者发送的。
- 验证者如何验证数字签名：
  1. 验证者通过与发送者相同的哈希算法对原始消息进行哈希。
  2. 然后，验证者使用发送方的公钥解密收到的数字签名，得到一个消息摘要。
  3. 最后，验证者比较这两个消息摘要，如果相同，则验证通过。

Q33. 数字证书接收者必须检查哪三点，以确保数字证书有效?

1. 首先，验证者必须检查数字证书是否真实且未被修改。
   - 许多国家的证书颁发机构（CA）并未受到监管，因此验证者必须仅接受其信任的CA所签发的证书。
   - 验证者可以使用CA的已知公钥来测试数字证书的数字签名，如果测试成功，则该数字证书是真实且未被修改的。
2. 其次，每个数字证书都有有效期，接收者必须检查数字证书是否在其有效期内。

数字证书：
1. 是否真实且违背修改：基于CA的公钥验证数字证书的数字签名；
2. 是否在有效期内；
3. 是否未被吊销

第三，即使在数字证书的有效期内，证书颁发机构（CA）也可能会吊销数字证书。

有一个在线证书状态协议（OCSP）。通过使用OCSP，程序可以向CA发送数字证书的序列号。CA将会返回一个响应，说明该序列号是有效的、已吊销的，还是未知的。

valid date：有效期；
revoke：吊销；